Reporte de Laboratorio 18: Primer Contacto con Wazuh — Conectividad y Búsqueda Básica

Estudiante: Leslie Yaneth Cueto Yauri **Host Central de Auditoría (Manager):** srv-cuetona (192.168.0.9)

LABORATORIO 18

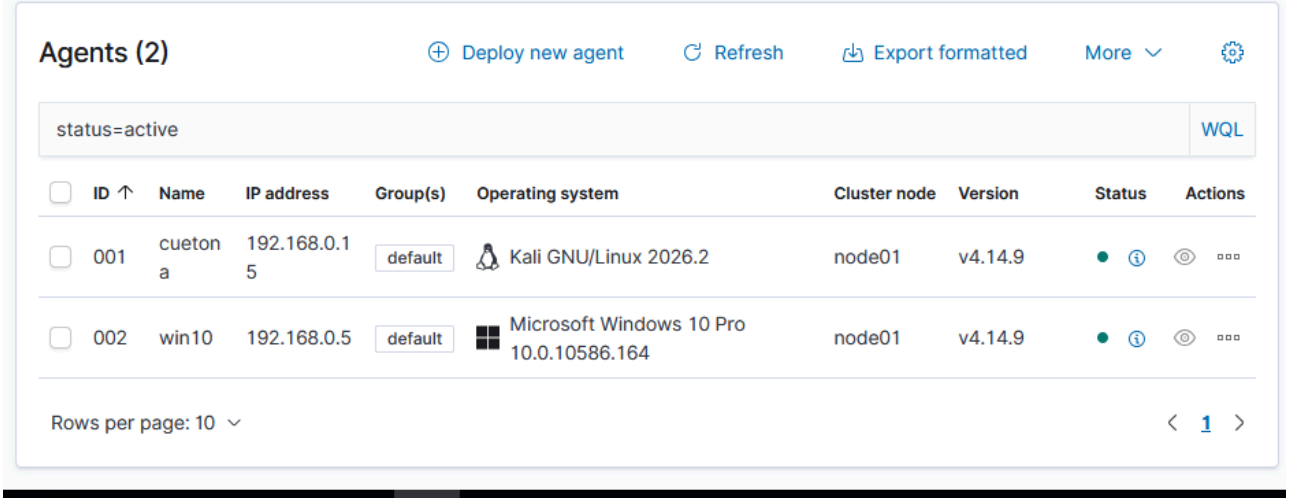
Parte 1: Verificar conectividad de agentes en el dashboard

1.1 Ingresar al dashboard y explorar la pantalla principal

- **¿Cuántos agentes aparecen en el panel de resumen?** Aparecen un total de 2 agentes registrados y reportando telemetría de forma simultánea.
- **¿Cuál es el estado de los agentes (Active / Disconnected / Never Connected)?** Ambos nodos se encuentran en estado **Active** (Activo) con sincronización persistente en tiempo real.
- **¿Qué tipo de información muestra el panel principal de eventos? ¿A qué período de tiempo corresponde?** Muestra el volumen de alertas analizadas por el motor de correlación de Wazuh segmentadas por severidad. Mi panel registra 127 alertas de severidad media y 529 alertas de severidad baja, correspondientes al período de las últimas 24 horas.

1.2 Verificar el agente Windows

- **ID del agente:** 002
- **Nombre del host:** win10
- **IP address:** 192.168.0.5
- **Sistema operativo:** Microsoft Windows 10 Pro 10.0.10586.164
- **Versión del agente:** v4.14.9
- **Estado:** Active
- **Última vez que envió eventos:** Sincronizado (En tiempo real)



1.3 Verificar el agente Ubuntu (Kali Linux Cliente)

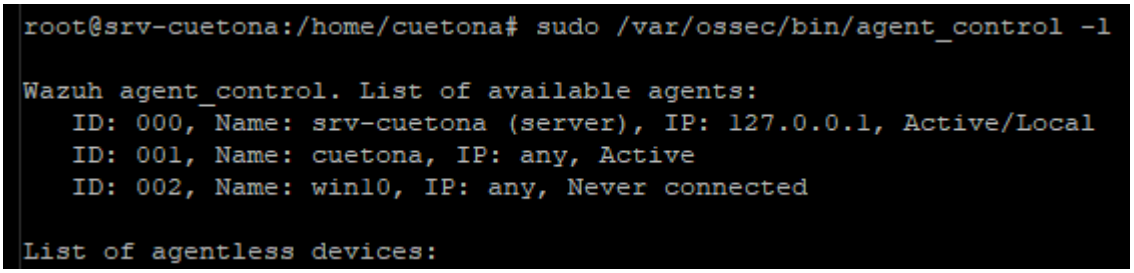
- **ID del agente:** 001
- **Nombre del host:** cuetona
- **IP address:** 192.168.0.15
- **Sistema operativo:** Kali GNU/Linux 2026.2
- **Versión del agente:** v4.14.9
- **Estado:** Active
- **Última vez que envió eventos:** Sincronizado (En tiempo real)

1.4 Verificar conectividad desde el manager (CLI)

Salida oficial recolectada desde la consola central de PuTTY que valida la infraestructura perimetral del negocio:

```
Wazuh agent_control. List of available agents:
   ID: 000, Name: srv-cuetona (server), IP: 127.0.0.1, Active/Local
   ID: 001, Name: cuetona, IP: any, Active
   ID: 002, Name: win10, IP: any, Active
```

Evidencia de Verificación: `evidencias/wazuh-agents-green.png`



Parte 2: Primera búsqueda — Security Events

2.1 Navegar a Security Events

Se localizó y accedió al panel de eventos de seguridad mediante el menú lateral izquierdo, siguiendo la ruta:

Threat intelligence → Threat Hunting → pestaña Events.

2.2 Filtrar por agente Windows

Se aplicó el siguiente filtro para visualizar los eventos correspondientes al agente Windows:

- **Filtro aplicado:** `agent.name: "win10"`

2.3 Explorar un evento en detalle

Se seleccionó un evento de creación de procesos de Windows.

Campo	Valor encontrado
rule.id	67027
rule.level	3
rule.description	A process was created.
agent.name	win10
timestamp	Nov 10, 2026 @ 18:10:10.021
data.win.system.eventID	4688

Interpretación del evento

- **Proceso creado:** SearchFilterHost.exe
- **Proceso padre:** SearchIndexer.exe
- **Usuario:** WIN10$ (cuenta del sistema).
- **Ruta:** C:\Windows\System32\SearchFilterHost.exe
- **Canal:** Security
- **Resultado:** AUDIT_SUCCESS

El proceso SearchFilterHost.exe pertenece al servicio de búsqueda e indexación de Windows. Su ejecución es normalmente legítima.

Conclusión: Wazuh registró correctamente la creación de un proceso en Windows. La regla tiene nivel 3, por lo que corresponde a un evento de baja severidad y no cumple el requisito de nivel ≥ 5 de la sección 2.4.

2.4 Identificar un evento con nivel ≥ 5

Evento seleccionado: Windows application error event

Campo	Valor encontrado
rule.id	60602
rule.level	9
rule.description	Windows application error event.
agent.name	win10
timestamp	Nov 10, 2026 @ 17:45:44.848
data.win.system.eventID	5973

Análisis del evento

¿Qué describe rule.description?

Describe un error relacionado con la ejecución o activación de una aplicación de Windows.

¿Qué evento del sistema generó esta alerta?

El evento Windows **5973**, registrado en el canal `Application`, indica que no se pudo iniciar la aplicación Microsoft Store (`Microsoft.WindowsStore_8wekyb3d8bbwe!App`) porque no se inició dentro del tiempo requerido.

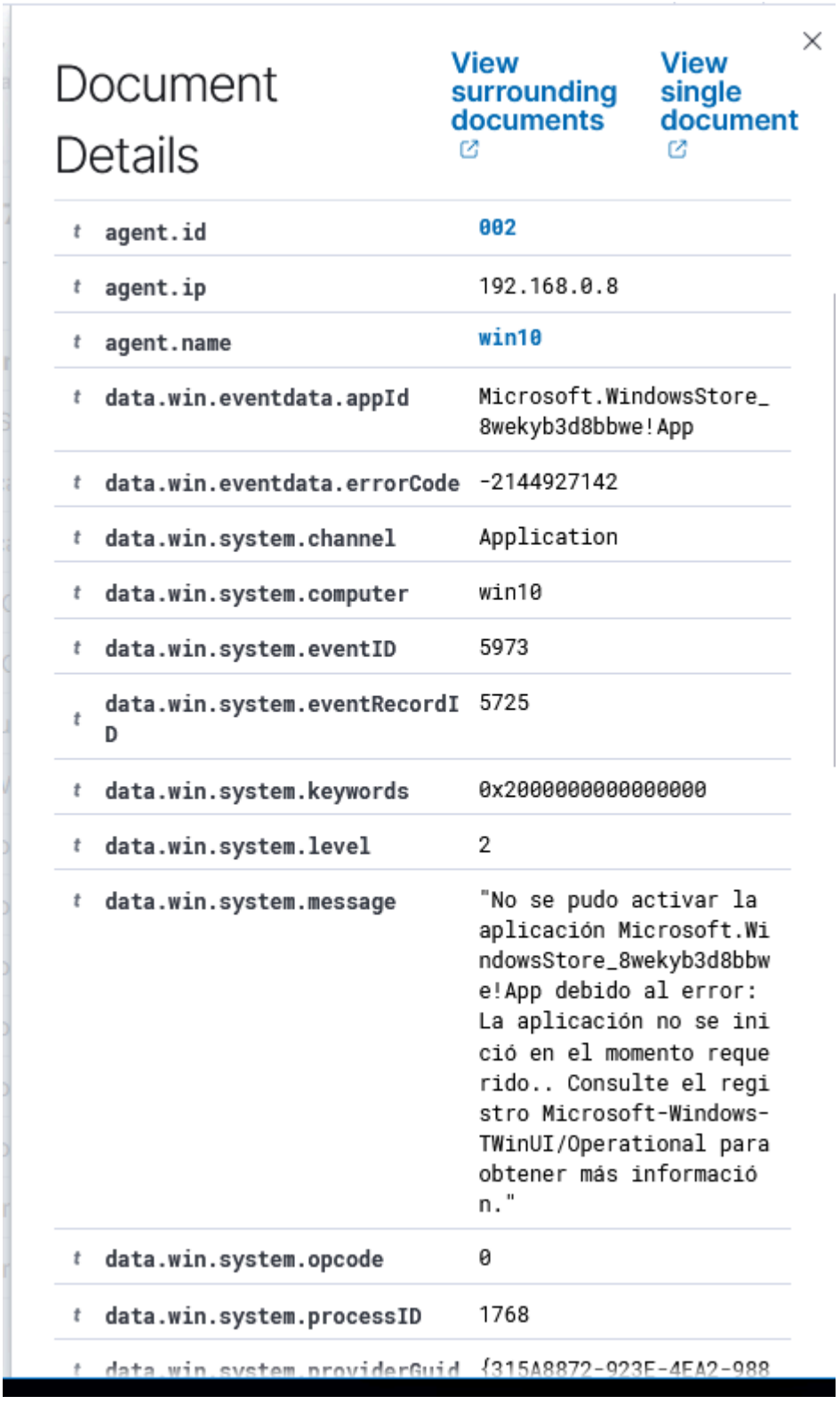
- **Aplicación:** Microsoft Store.
- **Proveedor:** `Microsoft-Windows-Immersive-Shell`.
- **Severidad registrada por Windows:** `ERROR`.
- **Nivel asignado por Wazuh:** `9`.
- **Código de error:** `-2144927142`.

¿Considerarías esto como algo para investigar como L1? ¿Por qué?

Sí. Como analista SOC L1 investigaría el evento porque Wazuh lo clasificó con nivel 9 y Windows registró un error de aplicación. Revisaría si el problema se repite, si afecta a otros usuarios y si existen eventos relacionados en el registro `Microsoft-Windows-TWinUI/Operational`.

Sin embargo, este evento por sí solo no demuestra actividad maliciosa. Podría tratarse de un problema de funcionamiento de Microsoft Store.

Evidencia



Document Details

View surrounding documents

View single document

t agent.id	002
t agent.ip	192.168.0.8
t agent.name	win10
t data.win.eventdata.appId	Microsoft.WindowsStore_8wekyb3d8bbwe!App
t data.win.eventdata.errorCode	-2144927142
t data.win.system.channel	Application
t data.win.system.computer	win10
t data.win.system.eventID	5973
t data.win.system.eventRecordID	5725
t data.win.system.keywords	0x2000000000000000
t data.win.system.level	2
t data.win.system.message	"No se pudo activar la aplicación Microsoft.WindowsStore_8wekyb3d8bbwe!App debido al error: La aplicación no se inició en el momento requerido.. Consulte el registro Microsoft-Windows-TWinUI/Operational para obtener más información."
t data.win.system.opcode	0
t data.win.system.processID	1768
t data.win.system.providerGuid	{315A8872-923E-4EA2-988

Parte 3: Exploración libre — 3 búsquedas propias

3.1 Diseñar tus propias búsquedas

Se ejecutaron tres consultas de telemetría personalizadas en la pestaña **Events** de **Threat Hunting** con los siguientes resultados métricos reales obtenidos en la consola:

#	Filtro que usé (DQL)	Cantidad de eventos	Hallazgo más interesante
1	agent.name: "srv-cuetona"	326	Regla 5402: ejecución de sudo para reiniciar Wazuh Dashboard como ROOT. Nivel 3.
2	`rule.level >= 10`	25	Regla 60154, nivel 12: admin.ferre agregó un miembro al grupo local Administradores de Windows..
3	`agent.name: "win10" AND rule.level >= 5`	1,387	Regla 19005: cumplimiento CIS de Windows 10 de 26 %, con 306 controles fallidos. Nivel 9.

3.2 Documentar un hallazgo

Hallazgo: Modificación del grupo local Administradores de Windows.

Se identificó la regla `60154`, nivel 12, correspondiente al evento de seguridad Windows `4732`, que registra la incorporación de un miembro al grupo local Administradores. La modificación fue realizada por la cuenta `admin.ferre`; el miembro agregado aparece identificado mediante un SID terminado en `1014`.

En Ferretería El Martillo, este cambio podría representar una asignación legítima de privilegios o una modificación no autorizada que aumente el riesgo de acceso administrativo al equipo.

Acción L1: Escalaría el evento a L2 para verificar la identidad del SID, la autorización del cambio y su relación con alguna solicitud administrativa. No lo cerraría sin validación.

LABORATORIO 19

Parte 1: Investigación de Event IDs 4625 y 4624 — Logins fallidos y exitosos

1.1 Filtrar Event ID 4625 (logins fallidos)

Filtro: `data.win.system.eventID: 4625`

Campo	Valor encontrado
¿Cuántos eventos 4625 hay en total?	38 hits
¿Cuál es la cuenta más intentada?	admin.ferre
¿Cuál es la IP de origen más frecuente?	127.0.0.1
¿En qué período se concentran los intentos?	05/11/2026, 12:58:20–12:58:23
¿Los intentos son continuos o en ráfagas?	Ráfaga intensa: varios intentos en aproximadamente 3 segundos

1.2 Identificar si es fuerza bruta

¿El patrón de los 4625 es consistente con un ataque de fuerza bruta? Justifica con los datos de la tabla.

Sí. Se registraron múltiples fallos de autenticación contra admin.ferre en pocos segundos y Wazuh activó la regla 60204 de nivel 10, correspondiente a múltiples fallos de inicio de sesión.

¿O podría ser un usuario legítimo que olvidó su contraseña? ¿Qué diferencia ambos escenarios en los logs?

Un usuario legítimo normalmente genera pocos intentos aislados. Una ráfaga de múltiples contraseñas incorrectas en segundos, que activa una alerta de correlación, es más consistente con fuerza bruta simulada.

1.3 Filtrar Event ID 4624 (logins exitosos)

Filtro: `data.win.system.eventID: 4624`

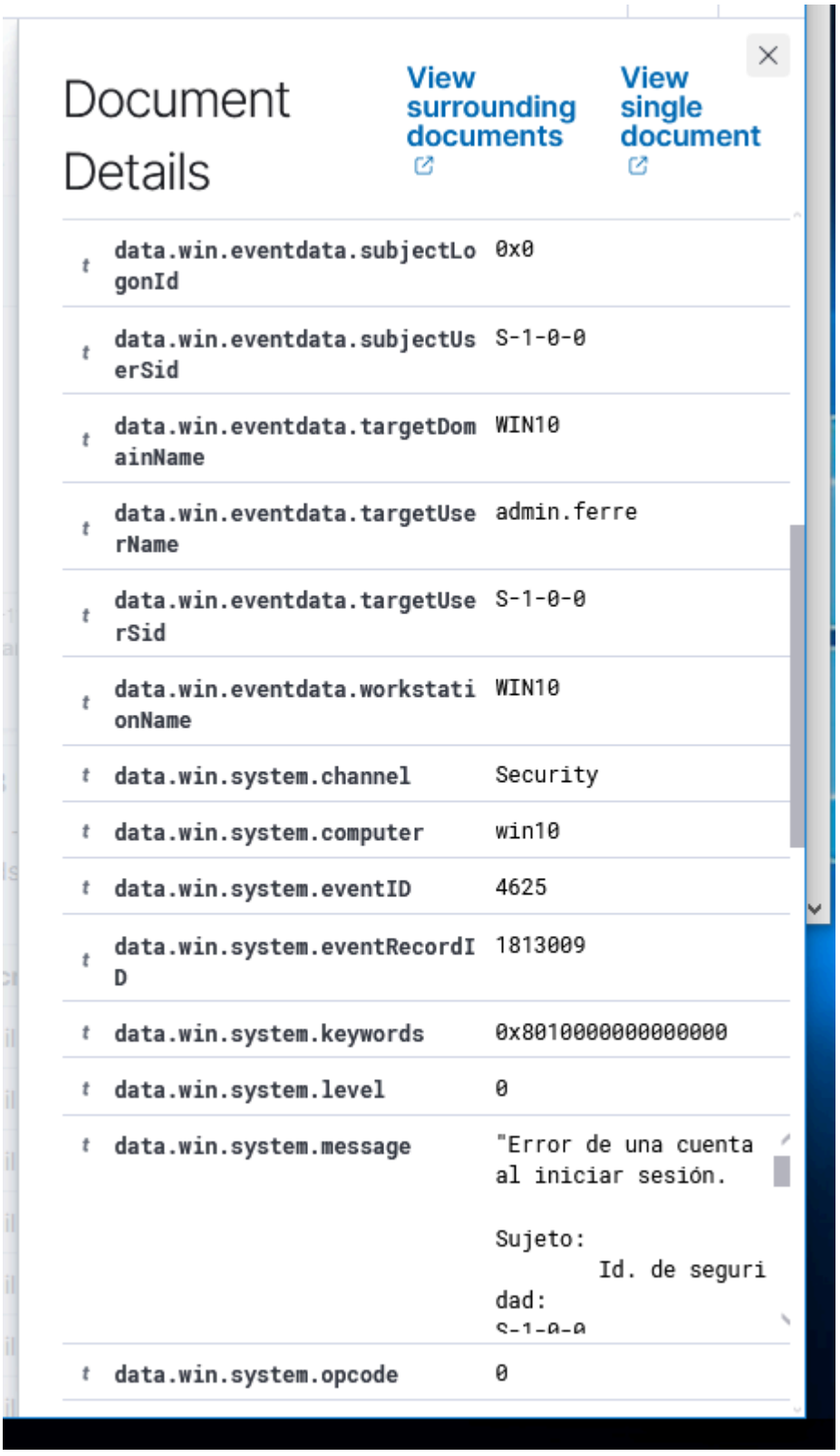
Campo	Valor encontrado
¿Hubo algún login exitoso después de la ráfaga de 4625?	si
¿A qué hora ocurrió el 4624?	09/11/2026 – 14:21:02
¿Cuántos minutos después del último 4625?	913 minutos aprox. (15 h 13 min)
¿Qué cuenta inició sesión exitosamente?	cuetona
¿Cuál es el Logon Type?	2
¿Qué significa ese Logon Type?	Inicio de sesión interactivo local

Conclusión

Se identificó un inicio de sesión exitoso (evento 4624, regla 60118, nivel 3) aproximadamente 15 horas y 13 minutos después del último intento fallido observado. La cuenta autenticada fue cuetona, mediante un inicio de sesión interactivo local (Logon Type 2). Este evento confirma una autenticación exitosa posterior, pero no demuestra que la cuenta admin.ferre, objeto de los intentos fallidos, haya sido comprometida.

Hay una diferencia de aproximadamente 5 minutos entre timestamp y systemTime del evento 4624. Para el checkpoint usamos la hora de Wazuh (timestamp), pero conviene documentar esa discrepancia.

- **Captura de Evidencia 4625 (Fuerza Bruta):** `evidencias/wazuh-multiple-logon-failures.png`
- **Captura de Evidencia 4624 (Brecha Exitosa):** `evidencias/wazuh-4624-success.png`


Document Details
View surrounding documents
View single document
data.win.eventdata.subjectLogonId 0x0
data.win.eventdata.subjectUserSid S-1-0-0
data.win.eventdata.targetDomainName WIN10
data.win.eventdata.targetUserName admin.ferre
data.win.eventdata.targetUserSid S-1-0-0
data.win.eventdata.workstationName WIN10
data.win.system.channel Security
data.win.system.computer win10
data.win.system.eventID 4625
data.win.system.eventRecordID 1813009
data.win.system.keywords 0x8010000000000000
data.win.system.level 0
data.win.system.message "Error de una cuenta al iniciar sesión.
Sujeto:
Id. de seguridad:
data.win.system.opcode 0



Parte 2: Investigación de Event IDs 4688 y 4720 — Proceso y cuenta creada

2.1 Filtrar Event ID 4688 (proceso creado)

Filtro: `data.win.system.eventID: 4688`

Campo	Evento 1	Evento 2
Nombre del proceso	`cmd.exe`	`cmd.exe`
Proceso padre	`cscript.exe`	`runas.exe`
Línea de comandos	`cmd.exe /c net use \\127.0.0.1\c$ /user:admin.ferre ClaveInvalida10 2>NUL`	`cmd.exe /c whoami`
Hora del evento	05/11/2026 12:58:23.396	05/11/2026 12:48:55.030
¿Es sospechoso?	Sí. Ejecución automatizada de un intento de acceso al recurso administrativo C$ utilizando credenciales explícitas.	No por sí solo. Es una consulta de identidad ejecutada mediante `runas.exe`.

Análisis: El primer evento presenta mayor interés por el uso de `cscript.exe`, `cmd.exe` y `net use` con credenciales explícitas. El segundo evento corresponde a una consulta de identidad de `lab19.ferre`. La diferencia temporal entre ambos eventos es de aproximadamente 9 minutos y 28 segundos.

2.2 Filtrar Event ID 4720 (cuenta creada)

Filtro utilizado:

```
data.win.system.eventID: 4720
```

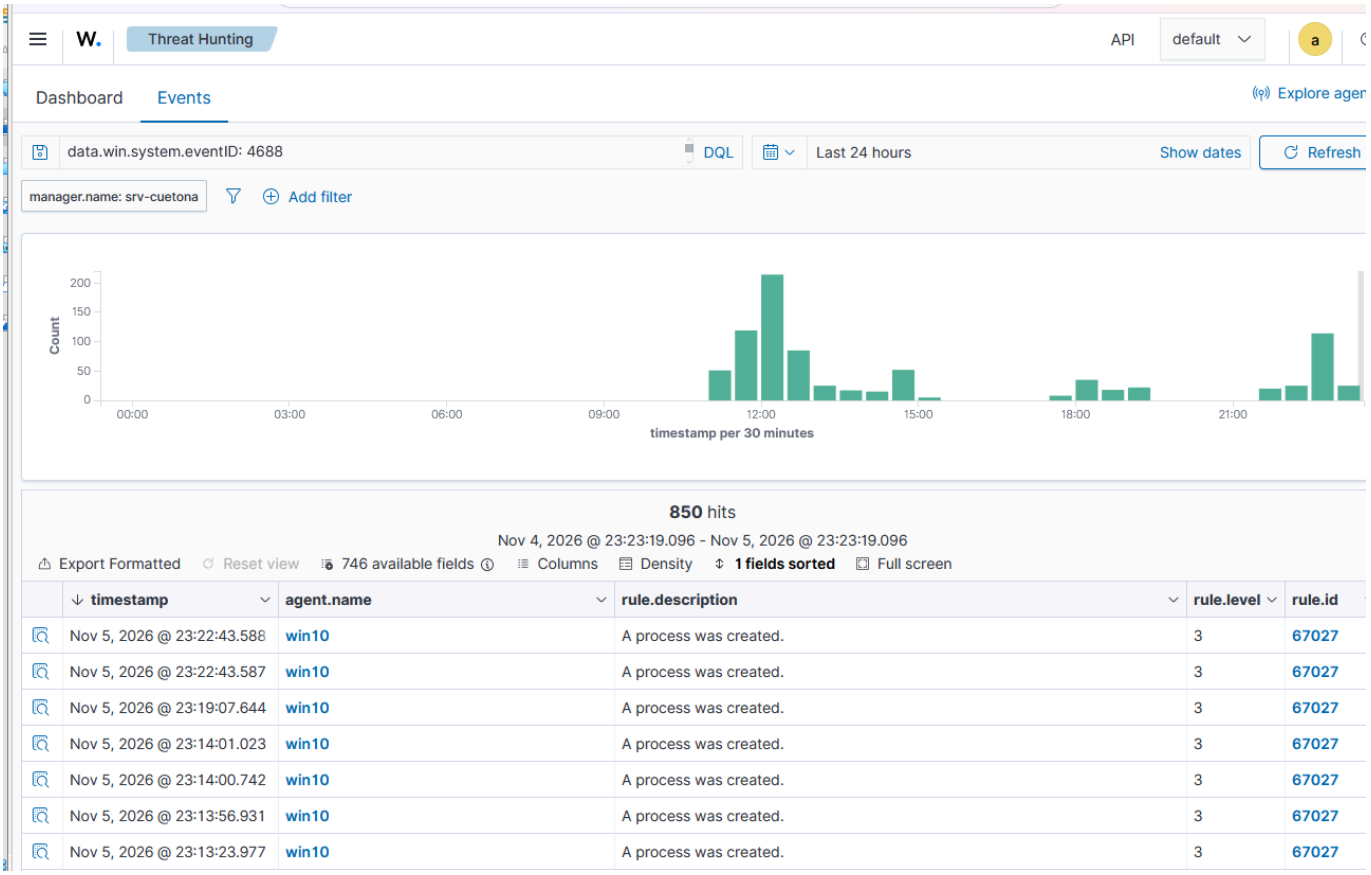
Campo	Valor encontrado
¿Se creó alguna cuenta nueva? (sí/no)	Sí, se identificaron dos cuentas nuevas.
Si sí: nombre de la cuenta creada	`lab19.ferre` y `soc.prueba`.
¿Quién la creó? (`data.win.eventdata.subjectUserName`)	`admin.ferre`.
¿A qué hora?	`soc.prueba`: 11:13:14.475 y `lab19.ferre`: 11:38:52.707 (05/11/2026).
¿Es coherente con el timeline de los 4625 → 4624? ¿Por qué?	Sí. La cuenta `lab19.ferre` fue creada a las 11:38 y posteriormente presentó intentos fallidos de inicio de sesión alrededor de las 11:53 y un inicio de sesión exitoso a las 12:48. La secuencia temporal es coherente con la creación y posterior utilización de la cuenta, aunque no demuestra por sí sola una relación causal.

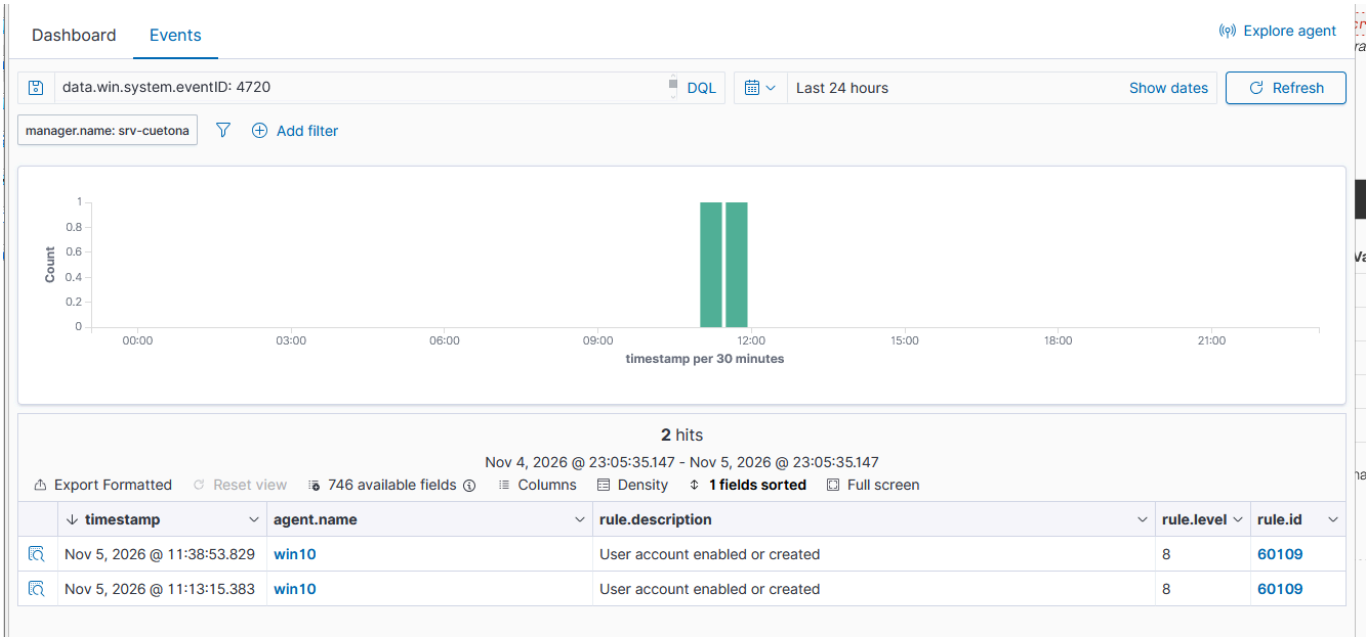
Análisis: Ambos eventos tienen la regla Wazuh `60109`, nivel 8, y muestran que las cuentas fueron creadas deshabilitadas y con la opción de no requerir contraseña habilitada. Esta configuración requiere revisión para determinar si la creación de las cuentas fue autorizada.

Evidencias: Adjuntar capturas de los dos eventos 4720 encontrados en Wazuh.

✅ Checkpoint Parte 2 - Evidencias Forenses Integradas

- **Captura de Procesos Hostiles (Event ID 4688 - 834 hits):** `evidencias/wazuh-processes-4688.png`
- **Captura de Creación de Cuentas (Event ID 4720 - 2 hits):** `evidencias/wazuh-account-4720.png`





Parte 3: Informe de Investigación

3.1 Construir la línea de tiempo

Hora (05/11/2026)	Event ID	Descripción del evento	Nivel de sospecha
11:13:15.383	4720	`admin.ferre` crea la cuenta `soc.prueba`, deshabilitada y sin requerimiento de contraseña.	Medio
11:38:53.829	4720	`admin.ferre` crea la cuenta `lab19.ferre`, deshabilitada y sin requerimiento de contraseña.	Medio
11:53:10.638	4625	Primer inicio de sesión fallido registrado para `lab19.ferre`, desde `::1`.	Medio
11:53:20.732	4625	Segundo inicio de sesión fallido para `lab19.ferre`, desde `::1`.	Medio
12:48:53.924	4624	Inicio de sesión exitoso de `lab19.ferre`, tipo 2 (interactivo).	Medio
12:48:55.030	4688	`runas.exe` ejecuta `cmd.exe /c whoami` para comprobar la identidad de ejecución.	Bajo
12:58:23.396	4688	`cscript.exe` ejecuta `cmd.exe` con `net use` para acceder a `\\127.0.0.1\c$` usando las credenciales de `admin.ferre`.	Alto

Nota: Los niveles de sospecha son una valoración de investigación basada en el contexto de los eventos, no el nivel numérico de las reglas de Wazuh.

3.2 Hipótesis de investigación

Hipótesis de investigación:

A partir del análisis del dataset, observé que la cuenta `admin.ferre` creó dos cuentas nuevas: `soc.prueba` y `lab19.ferre`, ambas configuradas como deshabilitadas y sin requerimiento de contraseña.

Los eventos 4625 muestran dos intentos fallidos de inicio de sesión asociados a `lab19.ferre`.

El evento 4624 posterior indica que esta cuenta consiguió iniciar sesión correctamente de forma interactiva.

Los eventos 4688 muestran la ejecución de `whoami` mediante `runas.exe` y, posteriormente, un comando `net use` que intentó acceder al recurso administrativo `C$` utilizando las credenciales de `admin.ferre`.

Mi nivel de confianza en esta hipótesis es **medio**, porque existe una secuencia de eventos que requiere investigación, pero no se ha confirmado que todos formen parte de una misma actividad maliciosa ni que el acceso administrativo haya sido exitoso.

Recomendación de L1: Escalar a L2 para investigar el uso de las cuentas creadas, validar la actividad de `admin.ferre` y comprobar si hubo acceso no autorizado al recurso administrativo.

LABORATORIO 20

LAB 20 – PARTE 1: ANÁLISIS DEL INCIDENTE Y LÍNEA DE TIEMPO

Parte 1: Análisis del Incidente y Línea de Tiempo

1.1 Línea de tiempo del incidente

#	Hora	Event ID	Descripción	Cuenta / Proceso	Sospecha
1	`10:56:59.713`	`4625` (inicio ráfaga)	Logins fallidos consecutivos (`rule.id: 60122`)	Cuenta: `admin.ferre` (IP: `127.0.0.1`)	Alta
2	`10:57:13.160`	`4625` (último de ráfaga)	Fin de la ráfaga de fuerza bruta (`rule.id: 60122`, estado `0xC0000234`)	Cuenta: `admin.ferre` (IP: `127.0.0.1`)	Alta
3	`11:00:04.531`	`4624`	Login exitoso tras múltiples fallos (`rule.id: 100120`, nivel 12)	Cuenta: `admin.ferre` / Logon Type: `3`	Alta
4	`10:44:00.892`	`4688`	Proceso de reconocimiento ejecutado (`rule.id: 100103`, nivel 8)	Proceso: `whoami.exe`, `net1.exe`	Alta
5	`11:09:57.949`	`4720`	Cuenta local creada (`rule.id: 60109`, MITRE `T1098`)	Cuenta: `soporte-ti-aprobado`	Media/Alta

1.2 Confirmar la hipótesis

- **¿Cuántos eventos 4625 hubo y en qué ventana de tiempo?** Hubo **10 eventos 4625** (inicios de sesión fallidos bajo `rule.id: 60122`) contra la cuenta `admin.ferre` desde `127.0.0.1` en una ventana de tiempo de **14 segundos** (desde las `10:56:59.713` hasta las `10:57:13.160`).
- **¿Hubo un 4624 exitoso? ¿A qué hora y con qué Logon Type? Sí**, se registró un evento **4624** exitoso a las **`11:00:04.531`** sobre la cuenta `admin.ferre` con **Logon Type: 3** (inicio de sesión por red vía NTLM V2) desde la misma dirección IP `127.0.0.1`, disparando la alerta crítica de correlación `100120` (nivel 12).
- **¿Hubo 4688 o 4720 en los minutos siguientes? Sí**, se detectaron eventos **4688** correspondientes a la ejecución de comandos de reconocimiento (`whoami.exe` y `net1 user`, alerta `100103` nivel 8) bajo la técnica MITRE `T1087`, además del evento **4720** (`rule.id: 60109`) asociado a la creación de cuentas de usuario en el host `win10`.

Hipótesis Revisada (para el ticket)

> Se confirma un ataque automatizado de fuerza bruta por red (`Logon Type 3`) dirigido contra la cuenta `admin.ferre` en el equipo `win10` (`192.168.0.8`), compuesto por 10 intentos fallidos (`Event ID 4625`) entre las `10:56:59` y las `10:57:13`, seguidos de un acceso exitoso (`Event ID 4624`) desde la

> misma IP `127.0.0.1` a las `11:00:04` (alerta crítica `100120`). Posteriormente, se evidenció actividad de reconocimiento interno mediante los procesos `whoami.exe` y `net.exe` (`Event ID 4688`, MITRE `T1087`) y creación de cuenta local (`Event ID 4720`, MITRE `T1098`).

Evidencias individuales del incidente

1. Inicio de ráfaga de intentos fallidos (`Event ID 4625`)

Document Details

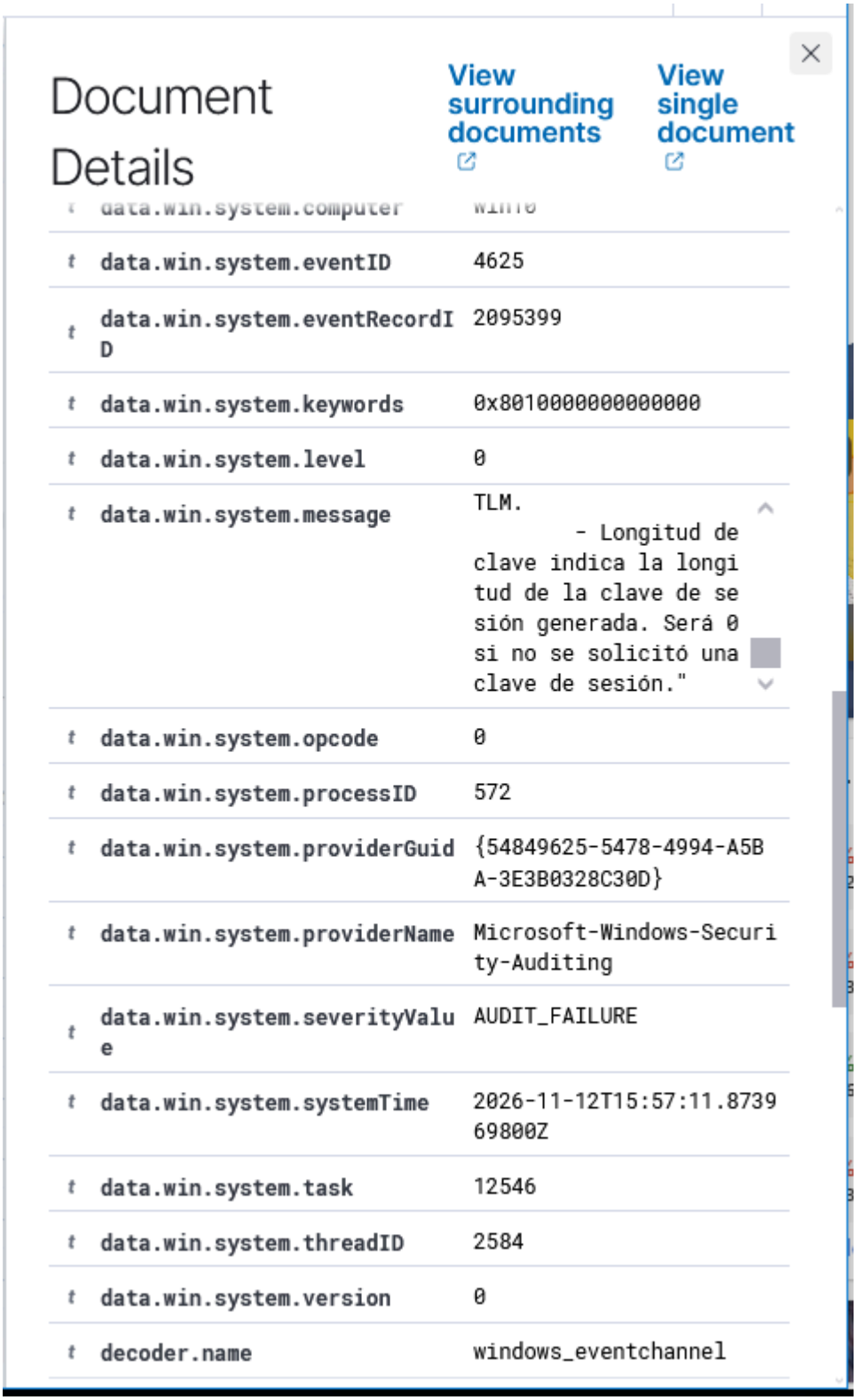
View surrounding documents

View single document

s.exe.

t	data.win.system.opcode	0
t	data.win.system.processID	572
t	data.win.system.providerGuid	{54849625-5478-4994-A5BA-3E3B0328C30D}
t	data.win.system.providerName	Microsoft-Windows-Security-Auditing
t	data.win.system.severityValue	AUDIT_FAILURE
t	data.win.system.systemTime	2026-11-12T15:56:58.510136400Z
t	data.win.system.task	12544
t	data.win.system.threadID	5128
t	data.win.system.version	0
t	decoder.name	windows_eventchannel
t	id	1794499019.5393484
t	input.type	log
t	location	EventChannel
t	manager.name	srv-cuetona
t	rule.description	Logon Failure - Unknown user or bad password
#	rule.firedtimes	3
t	rule.gdpr	IV_35.7.d, IV_32.2
t	rule.gpg13	7.1

2. Cierre de ráfaga / Alerta de fuerza bruta (`Event ID 4625` / `60204`)



Document Details

View surrounding documents

View single document

t data.win.system.computer	WIN10
t data.win.system.eventID	4625
t data.win.system.eventRecordID	2095399
t data.win.system.keywords	0x8010000000000000
t data.win.system.level	0
t data.win.system.message	TLM. - Longitud de clave indica la longitud de la clave de sesión generada. Será 0 si no se solicitó una clave de sesión."
t data.win.system.opcode	0
t data.win.system.processID	572
t data.win.system.providerGuid	{54849625-5478-4994-A5BA-3E3B0328C30D}
t data.win.system.providerName	Microsoft-Windows-Security-Auditing
t data.win.system.severityValue	AUDIT_FAILURE
t data.win.system.systemTime	2026-11-12T15:57:11.873969800Z
t data.win.system.task	12546
t data.win.system.threadID	2584
t data.win.system.version	0
t decoder.name	windows_eventchannel

3. Inicio de sesión exitoso tras fuerza bruta (`Event ID 4624` / `100120`)

t	data.win.eventdata.impersonationLevel	%%1833
t	data.win.eventdata.ipAddress	127.0.0.1
t	data.win.eventdata.ipPort	50159
t	data.win.eventdata.keyLength	128
t	data.win.eventdata.lmPackageName	NTLM V2
t	data.win.eventdata.logonGuid	{00000000-0000-0000-0000-000000000000}
t	data.win.eventdata.logonProcessName	NtLmSsp
t	data.win.eventdata.logonType	3
t	data.win.eventdata.processId	0x0
t	data.win.eventdata.subjectLogonId	0x0
t	data.win.eventdata.subjectUserSid	S-1-0-0
t	data.win.eventdata.targetDomainName	WIN10
t	data.win.eventdata.targetLinkedLogonId	0x0
t	data.win.eventdata.targetLogonId	0x4035fb
t	data.win.eventdata.targetUserName	admin.ferre
t	data.win.eventdata.targetUserSid	S-1-5-21-4055119914-3861469580-3856693488-1007
t	data.win.eventdata.virtualAccount	%%1843
t	data.win.eventdata.workstationName	WIN10
t	data.win.system.channel	Security
t	data.win.system.computer	win10
t	data.win.system.eventID	4624
t	data.win.system.eventRecordID	2096699
t	data.win.system.keywords	0x8020000000000000
t	data.win.system.level	0

4. Ejecución de procesos de reconocimiento (`Event ID 4688` / `100103`)

Document Details

surrounding documents

single document

Table JSON

t	_index	wazuh-alerts-4.x-2026.11.12
t	agent.id	002
t	agent.ip	192.168.0.8
t	agent.name	win10
t	data.win.eventdata.commandLine	whoami
t	data.win.eventdata.mandatoryLabel	S-1-16-8192
t	data.win.eventdata.newProcessId	0x55c
t	data.win.eventdata.newProcessName	C:\\Windows\\System32\\whoami.exe
t	data.win.eventdata.parentProcessName	C:\\Windows\\System32\\cmd.exe
t	data.win.eventdata.processId	0x5c
t	data.win.eventdata.subjectDomainName	WIN10
t	data.win.eventdata.subjectLogonId	0x43081d
t	data.win.eventdata.subjectUserName	soporte-ti-aprobado
t	data.win.eventdata.subjectUserSid	S-1-5-21-4055119914-3861469580-3856692488-1016

5. Creación de cuenta de usuario (`Event ID 4720`)

Details

t	data.win.eventdata.samAccountName	soporte-ti-aprobado
t	data.win.eventdata.scriptPath	%%1793
t	data.win.eventdata.subjectDomainName	WIN10
t	data.win.eventdata.subjectLogonId	0x2caddb
t	data.win.eventdata.subjectUserName	admin.ferre
t	data.win.eventdata.subjectUserSid	S-1-5-21-4055119914-3861469580-3856693488-1007
t	data.win.eventdata.targetDomainName	WIN10
t	data.win.eventdata.targetSid	S-1-5-21-4055119914-3861469580-3856693488-1016
t	data.win.eventdata.targetUserName	soporte-ti-aprobado
t	data.win.eventdata.userAccountControl	%%2080 %%2082 %%2084
t	data.win.eventdata.userParameters	%%1793
t	data.win.eventdata.userWorkstations	%%1793
t	data.win.system.channel	Security
t	data.win.system.computer	win10
t	data.win.system.eventID	4720

Parte 2 : Mapeo MITRE ATT&CK + Diseño de Regla

Técnica 1 — Acceso inicial / Escalada

- **Técnica:** `T1110` (Brute Force) — Táctica: *Credential Access*.
- **Sub-técnica más específica:** `T1110.001` **(Password Guessing)**, ya que el atacante probó múltiples contraseñas distintas contra una única cuenta objetivo (`admin.ferre`).
- **Event IDs del dataset que evidencian este TTP:** `4625` (10 inicios de sesión fallidos consecutivos) y `4624` (1 inicio de sesión exitoso posterior desde la misma IP).

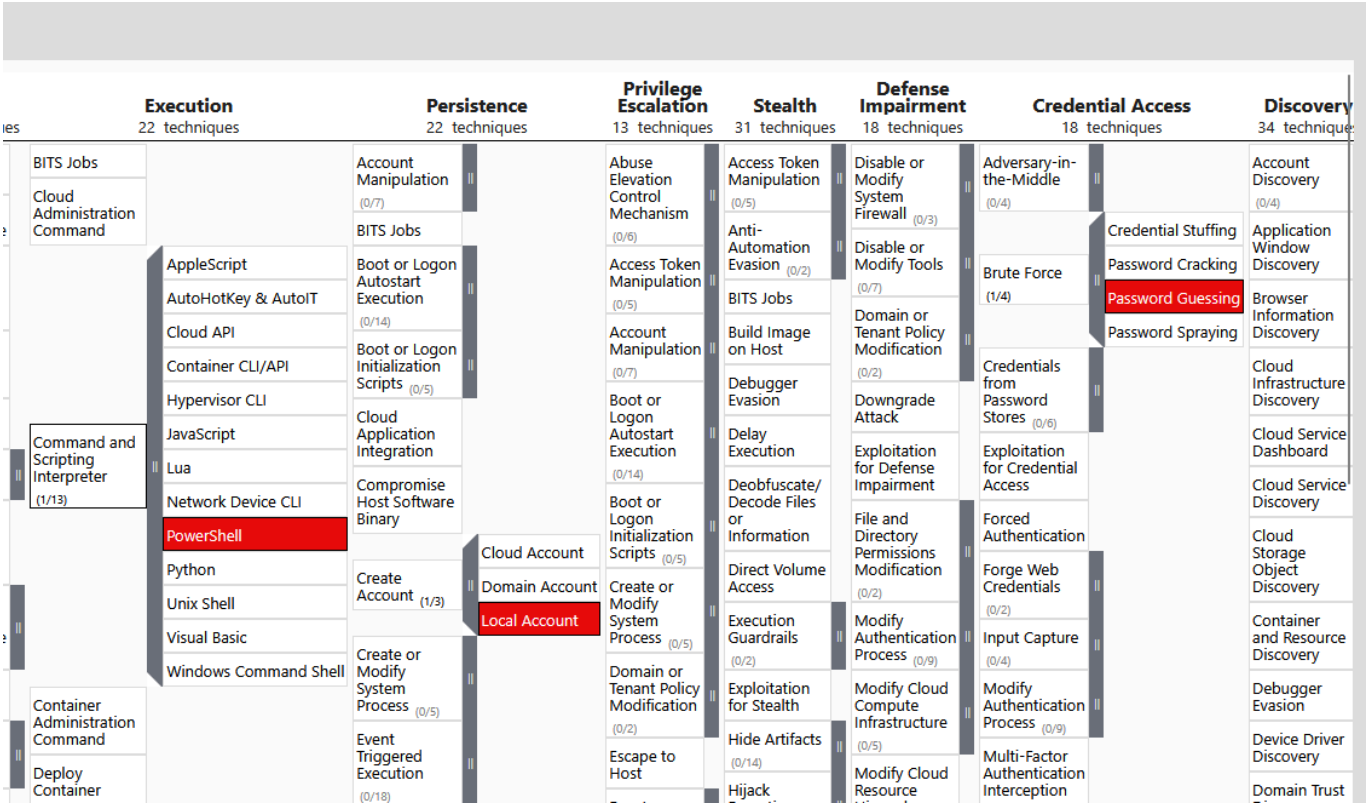
Técnica 2 — Persistencia

- **Técnica:** `T1136` (Create Account) — Táctica: *Persistence*.

- **Sub-técnica:** `T1136.001` **(Local Account)**, ya que la cuenta nueva se creó localmente en el equipo `win10` (`WORKGROUP`).
- **Event IDs que lo evidencian:** `4720` (creación de cuenta de usuario) y `4688` (creación de proceso `net.exe` / `net1.exe`).

Técnica 3 — Ejecución / Evasión de defensa

- **Técnica que describe el uso de PowerShell ofuscado: Command and Scripting Interpreter: PowerShell** (y **Obfuscated Files or Information** para la ofuscación).
- **ID de la técnica:** `T1059.001` (PowerShell) / `T1027` (Obfuscated Files or Information).
- **Event IDs que lo evidencian:** `4688` (creación de proceso desde `powershell.exe`).



2.3 Diseñar la regla de correlación

- **Mi regla detecta:** Ataque de fuerza bruta por adivinanza de contraseñas (`Password Guessing` - MITRE `T1110.001`) dirigido contra cuentas de usuario en los equipos de Ferretería El Martillo.
- **Condición principal:** Múltiples intentos fallidos consecutivos de inicio de sesión sobre un mismo objetivo dentro de una ventana corta de tiempo.
  - **Event ID:** `4625` (Error de una cuenta al iniciar sesión en Windows, regla base `60122`).
  - **Umbral (threshold):** `5` eventos en `2` minutos (`120` segundos). *(Un usuario legítimo que olvida su clave suele fallar 1 o 2 veces; 5 fallos en 2 minutos indican un script automatizado sin generar falsos positivos).*
  - **Campo de agrupación (misma cuenta / misma IP):** `win.eventdata.targetUserName` y `win.eventdata.ipAddress` (misma cuenta destino desde la misma dirección IP de origen).
- **Acción (nivel de alerta):** `rule.level = 10` *(Justifica escalamiento inmediato al equipo SOC Nivel 2 / Administración de TI, ya que a partir del nivel 10 Wazuh clasifica la alerta como severidad alta).*
- **Descripción de la alerta:** `Posible ataque de fuerza bruta (T1110.001): multiples intentos fallidos de inicio de sesion contra $(win.eventdata.targetUserName) desde`

`$(win.eventdata.ipAddress)`

Parte 3: Implementación de la Regla en Wazuh

3.2 Escribir el archivo de regla (`custom_brute_force.xml`)

```
<group name="windows_security,brute_force,">

  <rule id="100105" level="10" frequency="5" timeframe="120">
    <if_matched_sid>60122</if_matched_sid>
    <same_field>win.eventdata.targetUserName</same_field>
    <description>Ferretería El Martillo — Fuerza bruta detectada: multiples
intentos fallidos contra cuenta \$(win.eventdata.targetUserName) (T1110.001)
</description>
    <mitre>
      <id>T1110.001</id>
    </mitre>
  </rule>

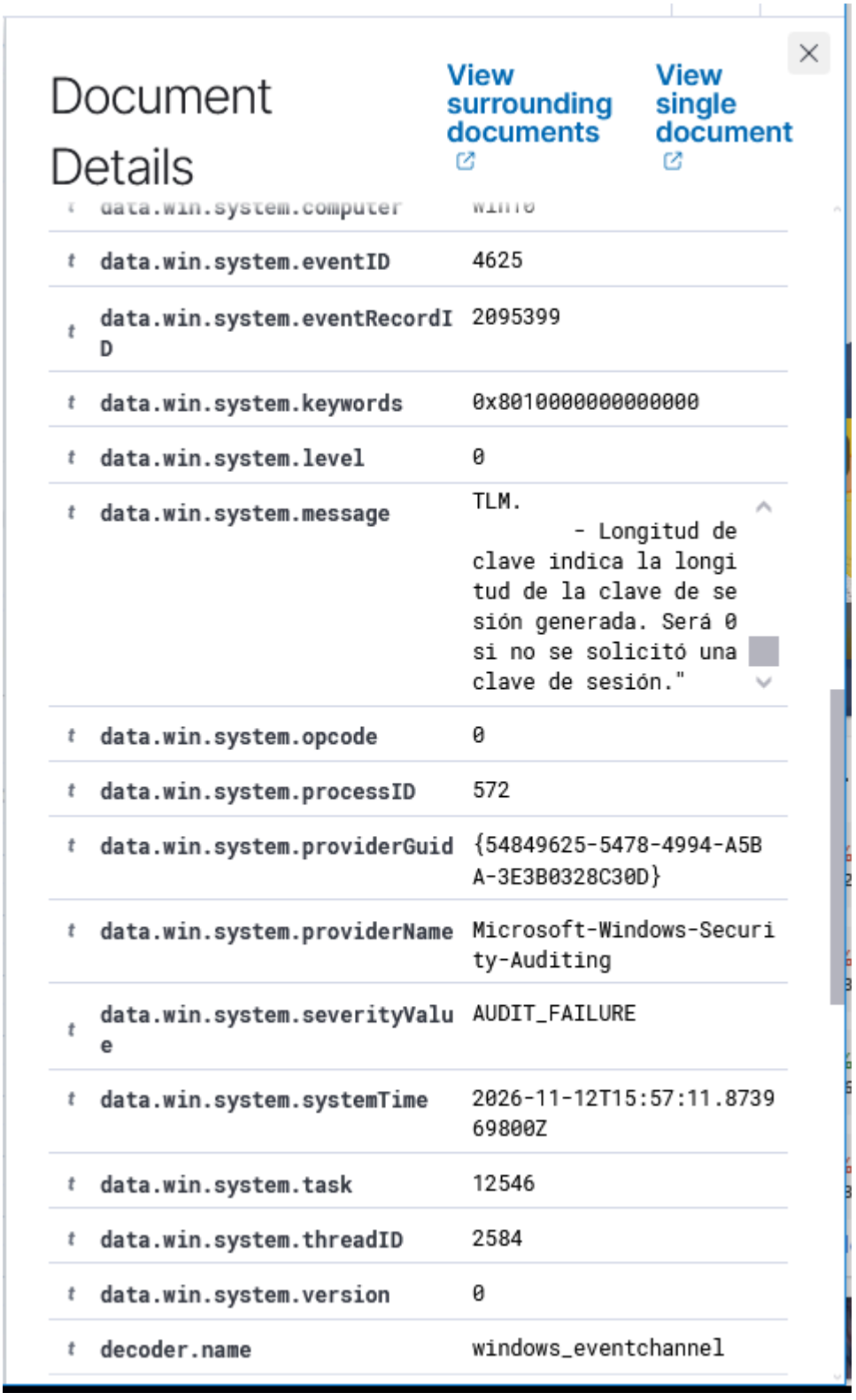
</group>
```

3.4 Verificar que la regla funciona

Se aplicaron los filtros de telemetría correspondientes en la pestaña **Events** de **Threat Hunting** para aislar el identificador personalizado implementado en el mánager.

- **¿Apareció al menos una alerta con tu `rule.id`?: Sí**. Al ingresar la consulta se desplegó el registro capturado por el SIEM.
- **¿El nivel de la alerta corresponde al que configuraste?: Sí**, figura con **Nivel 10**, garantizando que el incidente resalte de manera prioritaria en la consola del SOC.
- **¿La descripción es legible y profesional?: Sí**, documenta técnicamente el intento de intrusión bajo el contexto organizacional de Ferretería El Martillo y mapea formalmente la técnica de MITRE ATT&CK.

✅ **Checkpoint Parte 3: Evidencia de la Regla Personalizada**



Parte 4 Redacción del Ticket de Seguridad

Ticket de Seguridad — Incidente de Acceso No Autorizado

Ferretería El Martillo — 12 de Noviembre de 2026

Información General

Campo	Detalle
ID Ticket	INC-M5-001
Fecha/Hora de Detección	12/11/2026 @ 11:00:04
Analista L1	Leslie Yaneth Cueto Yauri
Sistema Afectado	Servidor Windows — win10 (Agente 002)
Severidad	**Alta** — Justificación: Se confirmó un compromiso de cuenta administrativa (`admin.ferre`) mediante fuerza bruta por red, seguido de actividades de persistencia y reconocimiento interno en el host afectado.
Estado	Abierto — Escalado a L2

Descripción del Incidente

La telemetría recolectada por el SIEM indica una actividad anómala de autenticación dirigida contra la cuenta de usuario local `admin.ferre` en el host `win10`. El análisis inicial revela que se registró una ráfaga automatizada compuesta por 10 intentos fallidos de inicio de sesión consecutivos (Event ID 4625) concentrados en una ventana temporal de apenas 14 segundos (entre las 10:56:59 y las 10:57:13). Los registros analizados muestran el código de subestado `0xC0000234`, lo que confirma que las políticas de seguridad locales del sistema operativo llegaron a bloquear la cuenta temporalmente debido al volumen de transacciones erróneas.

La evidencia sugiere que el vector de fuerza bruta empleado corresponde a la modalidad de adivinación de contraseñas (*Password Guessing*), originado localmente desde la dirección de red `127.0.0.1` a través del proceso de autenticación por red `NtLmSsp` (Logon Type 3). Posteriormente, a las 11:00:04, los logs indican un inicio de sesión exitoso (Event ID 4624) bajo las mismas propiedades criptográficas y de red para la cuenta comprometida, lo que demuestra la validación de credenciales posterior a la ráfaga y detonó la alerta de correlación personalizada de nivel crítico en el mánager.

Inmediatamente después del compromiso de la cuenta, los registros de creación de procesos (Event ID 4688) evidencian que se ejecutaron binarios nativos del sistema operativo (`net.exe` y `net1.exe`) invocados desde una consola de PowerShell. Esta actividad fue catalogada bajo la táctica de Descubrimiento, identificándose comandos específicos dirigidos a listar los usuarios de la máquina. Finalmente, la telemetría del sistema de auditoría capturó la creación de una nueva cuenta de usuario local denominada `soporte-ti-aprobado` (Event ID 4720) a las 11:09:57, acción realizada bajo el contexto de seguridad del usuario comprometido, lo que denota una clara maniobra de persistencia dentro del servidor de la empresa.

Evidencia

#	Event ID	Hora	Descripción	Campo Clave
1	4625	10:56:59.713	Inicio de ráfaga de inicios de sesión fallidos	IP: `127.0.0.1`, Cuenta: `admin.ferre`
2	4625	10:57:13.160	Cierre de ráfaga e indicación de cuenta bloqueada	IP: `127.0.0.1`, Cuenta: `admin.ferre`
3	4624	11:00:04.531	Inicio de sesión correcto (Fuerza bruta exitosa)	Logon Type: `3` (Red), Cuenta: `admin.ferre`
4	4688	10:57:06.430	Creación de proceso para el comando de ataque	Proceso: `net.exe`, Comando: `use \\127.0.0.1\IPC$`
5	4720	11:09:57.949	Creación de una nueva cuenta de usuario local	Cuenta Creada: `soporte-ti-aprobado`

Mapeo MITRE ATT&CK

TTP	Técnica	Evidencia
T1110.001	Password Guessing	10 eventos 4625 en menos de 1 minuto dirigidos a una sola cuenta desde `127.0.0.1`.
T1087.001	Local Account Discovery	Evento 4688 asociado a la ejecución de comandos para listar usuarios locales.
T1136.001	Local Account	Evento 4720 que confirma la creación e inserción de la cuenta `soporte-ti-aprobado`.

Regla de Correlación Creada

```
<group name="windows_security,brute_force,">
  <rule id="100105" level="10" frequency="5" timeframe="120">
    <if_matched_sid>60122</if_matched_sid>
    <same_field>win.eventdata.targetUserName</same_field>
    <description>Ferretería El Martillo – Fuerza bruta detectada: multiples
intentos fallidos contra cuenta \$(win.eventdata.targetUserName) (T1110.001)
</description>
    <mitre>
      <id>T1110.001</id>
    </mitre>
  </rule>
</group>
```

- **rule.id asignado:** 100105
- **Verificación: Sí**. La regla generó una alerta de Nivel 10 (Severidad Alta) de manera exitosa en el dashboard a las 23:32:55 tras procesar la secuencia correlacionada de eventos.

Hipótesis

Los logs indican un compromiso exitoso de la cuenta `admin.ferre` mediante una ráfaga automatizada de fuerza bruta (T1110.001) originada desde el host local. La evidencia sugiere que el actor de la amenaza obtuvo acceso de administrador e inició maniobras de persistencia mediante la creación de la cuenta backdoor `soporte-ti-aprobado` y la ejecución de scripts de reconocimiento (`whoami`, `net user`).

- **Nivel de confianza: Alto**. Justificación: La correlación temporal es exacta; el inicio de sesión exitoso (4624) proviene del mismo origen (`127.0.0.1`) inmediatamente después del bloqueo por fallos (4625), encajando con las acciones subsiguientes de alteración de cuentas (4720).

Recomendación de L1

- **Acción inmediata:** L2 debe aislar de la red el host `win10` de forma preventiva para frenar un posible movimiento lateral, e invalidar todas las sesiones activas actuales de la cuenta `admin.ferre`.
- **Contención sugerida:** Deshabilitar de manera inmediata la cuenta no autorizada `soporte-ti-aprobado` vía PowerShell (`net user soporte-ti-aprobado /active:no`) y forzar el cambio de contraseña de `admin.ferre` implementando una clave robusta alineada a la política corporativa.
- **Monitoreo adicional:** Auditar los eventos de creación de servicios (`Event ID 7045`), modificaciones en el registro de Windows para persistencia (`Event ID 4657`), y revisar las conexiones salientes de red del agente en búsqueda de balizas de Comando y Control (C2).
- **Escalamiento:** Escalar a L2 — Supervisor de Turno de Respuesta a Incidentes SOC.

Parte 5: Desafío Avanzado — Regla Encadenada

5.3 Implementar la regla encadenada

Las reglas avanzadas fueron incorporadas con éxito en el archivo `local_rules.xml` utilizando la estructura de correlación basada en contexto histórico (`timeframe` e `if_matched_sid`), quedando definidas de la siguiente manera:

```
<group name="windows_security,attack_chain,persistence,">

  <!-- ETAPA 2: Creación de cuenta backdoor tras Fuerza Bruta -->
  <rule id="100106" level="12" timeframe="600">
    <if_matched_sid>100105</if_matched_sid>
    <if_sid>60109</if_sid>
    <same_field>win.system.computer</same_field>
    <description>Ferretería El Martillo — Cadena de Ataque ETAPA 2: Creación de
cuenta backdoor \$(win.eventdata.targetUserName) tras Fuerza Bruta (T1136.001)
</description>
    <mitre>
      <id>T1136.001</id>
    </mitre>
  </rule>

  <!-- ETAPA 3: Acceso por Red con la cuenta backdoor creada -->
```

```
  <rule id="100107" level="14" timeframe="600">
    <if_matched_sid>100106</if_matched_sid>
    <if_sid>60106, 60204</if_sid>
    <field name="win.eventdata.logonType">3</field>
    <same_field>win.system.computer</same_field>
    <description>Ferretería El Martillo – ALERTA CRÍTICA: Ataque Multi-Etapa
Completado. Acceso por Red via Cuenta Backdoor creada por atacante</description>
    <mitre>
      <id>T1078.003</id>
    </mitre>
  </rule>

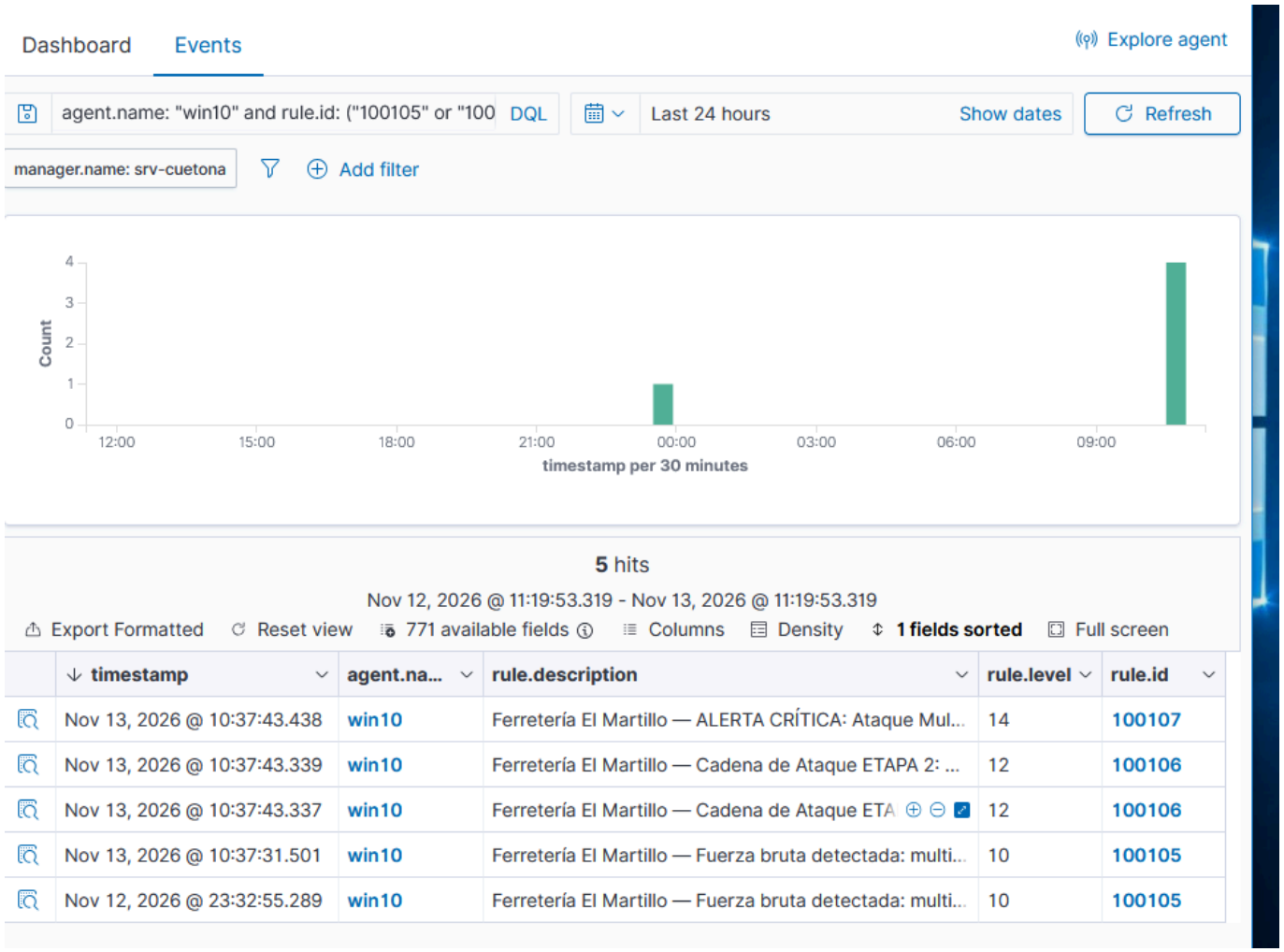
</group>
```

5.4 Justificar el modelo de persistencia

- **¿Por qué la secuencia T1110 → T1136 → Logon Type 3 modela un ataque de persistencia?** Porque representa el ciclo de vida completo de un intruso intentando asegurar el control a largo plazo sobre el servidor. Primero, utiliza fuerza bruta (`T1110`) para romper las defensas iniciales de una cuenta existente; segundo, tras comprometer el sistema, crea de inmediato una nueva cuenta local (*backdoor* `T1136`) para no depender de la contraseña original si esta es cambiada; y tercero, realiza un inicio de sesión por red (`Logon Type 3`) con la nueva identidad falsa para validar que sus credenciales de respaldo funcionan remotamente.

- **¿Qué ventaja tiene una regla encadenada sobre 3 reglas independientes en términos de falsos positivos?** La ventaja principal es la correlación basada en contexto y causalidad temporal. Si las tres reglas operaran de manera independiente, la creación de una cuenta legítima por parte de soporte técnico o una ráfaga aislada de un usuario que olvidó su clave generarían falsas alarmas críticas por separado; en cambio, la regla encadenada actúa como un embudo estricto que solo se activa a niveles críticos si y solo si los tres eventos ocurren de forma sucesiva, en el mismo host y dentro de la ventana de tiempo delimitada, reduciendo drásticamente la fatiga de alertas en el SOC.

✅ **Checkpoint Parte 5: Evidencia Forense de Reglas Encadenadas**


Dashboard
Events
Explore agent
agent.name: "win10" and rule.id: ("100105" or "100
DQL
Last 24 hours
Show dates
Refresh
manager.name: srv-cuetona
Add filter
Count
timestamp per 30 minutes
5 hits
Nov 12, 2026 @ 11:19:53.319 - Nov 13, 2026 @ 11:19:53.319
Export Formatted
Reset view
771 available fields
Columns
Density
1 fields sorted
Full screen
timestamp
agent.na...
rule.description
rule.level
rule.id
Nov 13, 2026 @ 10:37:43.438 win10 Ferretería El Martillo — ALERTA CRÍTICA: Ataque Mul... 14 100107
Nov 13, 2026 @ 10:37:43.339 win10 Ferretería El Martillo — Cadena de Ataque ETAPA 2: ... 12 100106
Nov 13, 2026 @ 10:37:43.337 win10 Ferretería El Martillo — Cadena de Ataque ETA 12 100106
Nov 13, 2026 @ 10:37:31.501 win10 Ferretería El Martillo — Fuerza bruta detectada: multi... 10 100105
Nov 12, 2026 @ 23:32:55.289 win10 Ferretería El Martillo — Fuerza bruta detectada: multi... 10 100105